

אבטחת מידע – מדריך למורה

תכנית הלימודים "אבטחת מידע" – מגמת תקשוב, משרד החינוך

חומר עיון מלא, שאלות תלמידים נפוצות, טעויות נפוצות ושאלות בסגנון בגרות
(שאלון 735001)

120 שעות · 9 פרקים · תכנון ל-30 שבועות (4 ש"ש)

מבוסס על תכנית הלימודים הרשמית ועל מבנה שאלון הבגרות "רשתות תקשורת ואבטחת מידע"

מבוא: איך להשתמש בחומר הזה

קראו את הפרק הזה לפני שמתחילים ללמוד

מה יש כאן

החומר בנוי משני חלקים שמשלימים זה את זה:

- **מדריך למורה (ה-PDF הזה)** – פרק לכל פרק בתכנית הלימודים. כל פרק כולל: מטרות ותכנון שעות, את החומר העיוני עצמו בעומק שמאפשר לענות על שאלות של תלמידים, מדריך פקודות CLI, תיבות "שאלת תלמיד נפוצה" עם תשובה מוכנה, תיבות "טעות נפוצה", תיבות "טיפ להוראה", ושאלות בסגנון בגרות עם פתרון מלא.
- **מצגות (תיקית slides)** – קובץ HTML אחד לכל פרק, פותחים בדפדפן ומקרנים. עובד ללא אינטרנט. לחיצה על N פותחת הערות למורה בתחתית המסך (מה להגיד, איזו שאלה לשאול את הכיתה). לחיצה על F – מסך מלא. חיצים / רווח – מעבר שקף. בשקפי "שאלה" התשובה מופיעה רק בלחיצה נוספת – כך אפשר לתת לכיתה לנסות קודם.

טיפ: סדר עבודה מומלץ לכל שבוע

1. קראו את פרק המדריך הרלוונטי (30-60 דקות). 2. עברו על המצגת עם הערות המורה פתוחות. (N)
3. הריצו בעצמכם את פקודות ה-CLI ב-Packet Tracer לפני השיעור – תלמידים ישאלו "מה קורה אם..." ועדיף שכבר ראייתם. 4. אחרי השיעור – תנו לתלמידים את שאלות "סגנון בגרות" מהמדריך כתרגול.

על תכנית הלימודים ועל שאלון הבגרות

תכנית הלימודים הרשמית (120 שעות: 96 עיוני + 24 מעשי) מבוססת על קורס CCNA Security של סיסקו מהדור הקודם. שימו לב לשלושה דברים:

1. **SDM / CCP הם כלים שיצאו משימוש**. התכנית מזכירה הרבה "הגדרה על ידי SDM" (ממשק גרפי של סיסקו לנתבים). SDM הוחלף ב-CCP וגם הוא הופסק. **שאלון הבגרות בודק אך ורק** CLI. לכן במדריך הזה ההגדרות הן ב-CLI, ואת SDM אנו מזכירים רק כמושג ("קיים גם ממשק גרפי").
2. **בתכנית הרשמית יש שגיאת העתקה**: רשימת הנושאים של פרק 3 (AAA) זהה לרשימה של פרק 2. במדריך הזה פרק 3 בנוי לפי המטרות של פרק 3 (מודל AAA, ACS, TACACS+, RADIUS) – זה גם מה שנשאל בבגרות.
3. **מחצית משאלון הבגרות (50 נקודות) היא "רשתות תקשורת"** – סאבנטים, DHCP, STP, OSPF, ניתוב סטטי, VLAN וכו'. החומר הזה אל נמצא בתכנית "אבטחת מידע" והוא נלמד בקורס הרשתות. במדריך הזה נגענו בו רק היכן שהוא נוגע ישירות לאבטחה (למשל STP בפרק 6, ACL בפרק 4, פקודות line vty בפרק 2). מומלץ לוודא שהתלמידים מגיעים עם רקע ב-CCNA 1-2.

תכנון שנתי – 30 שבועות, 4 שעות שבועיות

שבועות	פרק	שעות בתכנית	מה מכסים	מעשי
3-1	פרק 1 – מבוא לאיומי רשת	10	מושגי יסוד (CIA), אבולוציית האיומים, סוגי תוקפים, נזקות, שלבי תקיפה, DoS/DDoS, הנדסה חברתית, ברוט-פורס. שבוע 1: היכרות עם הקורס ומבחן רמה קצר ברשתות.	Wireshark / דמו phishing

שבועות	פרק	שעות בתכנית	מה מכסים	מעשי
6-4	פרק 2 - אבטחת אביזרי רשת	12	הקשחת נתב: enable, סיסמאות, secret, SSH, רמות הרשאה, banner, syslog, NTP, SNMP, AutoSecure, OOB.	:Packet Tracer הקשחת נתב + SSH
9-7	פרק 3 - מודל AAA	14	Authentication/Authorization/Accounting, AAA מקומי, RADIUS מול TACACS+, ACS/ISE, פקודות AAA.	:Packet Tracer שרת RA- + DIUS/TACACS
12-10	פרק 4 - חומות אש	13	ACL סטנדרטי/מורחב, wildcard מיקום, ACL מבוסס זמן-/reflexive/dy, namic סוגי חומות אש, CBAC, ZPF.	Packet Tracer: ACL + ZPF
16-13	פרק 5 - IDS / IPS	14	IDS מול IPS, חתימות, HIPS מול NIPS, אזעקות (true/false positive), IOS IPS ניטור ופתרון תקלות. שבוע 16: חזרה + מבחן מחצית.	Packet Tracer: IOS IPS
19-17	פרק 6 - אבטחת הרשת המקומית	13	התקפות שכבה 2: MAC flooding, VLAN hopping/DTP, STP, DHCP/ARP spoofing. הגנות: port security, BPDU guard, DHCP snooping, DAI, storm control, SPAN. NAC, IronPort, VoIP/SAN, Evil Twin.	Packet Tracer: port security + BPDU guard

שבועות	פרק	שעות בתכנית	מה מכסים	מעשי
23-20	פרק 7 - הצפנה וקריפטולוגיה	14	היסטוריה (קיסר, ויז'נר), CIA + הצפנה, גיבוב (MD5/SHA), HMAC, סימטרי (DES/3DES/AES), א-סימטרי (RSA/DH), חתימה דיגיטלית, PKI.	תרגול: צופן קיסר, hash בפייטון/אונליין
26-24	פרק 8 - VPN	13	סוגי VPN, GRE, IPsec (AH/ESP, IKE, DH), site-to-site ב-VPN, CLI, SSL (ASA). ציוד.	Packet Tracer: GRE + IPsec site-to-site
29-27	פרק 9 - ניהול אבטחה מתקדם	14	ניהול סיכונים, סוגי בקורות (מנהלי/פיזי/לוגי), בדיקות חדירה, Nmap/Nessus, BCP/DRP, SDLC, מדיניות ואתיקה.	Nmap במעבדה מבודדת
30	חזרה לבגרות	3	פתרון שאלון לדוגמה בתנאי אמת, חזרה על פקודות.	

מיפוי שאלון הבגרות (חלק ב' - אבטחת מידע) לפרקי הקורס

ניתחנו את שאלון 735001 (אביב תשפ"ג). כך מתפלגים נושאי חלק ב' (50 נקודות) בין הפרקים - זה אומר לכם על מה לשים דגש:

נושא שנשאל	פרק	סוג שאלה
זיהוי הודעת phishing / הנדסה חברתית	1	רב-ברירה על תמונה
סוגי תוקפים: Script kiddies, Hactivist, Insider פשע מאורגן	1	התאמה
Brute force (מילון), Buffer overflow, DoS, Port redirection	1	רב-ברירה
הפקת מפתחות RSA - משמשים SSH-ל	2	רב-ברירה
שלושת שירותי AAA (הגדרות) RADIUS מול TACACS+	3	התאמה
(הצפנה, UDP/TCP, הרשאות)	3	נכון/לא נכון
הפקודה aaa new-model	3	השלמת פקודה
ACL סטנדרטי לחסימת רשת; מיקום ACL וכיוון (in/out)	4	רב-ברירה
IDS מול IPS	5	התאמה

נושא שנשאל	פרק	סוג שאלה
MAC table נגד Port security VLAN-overflow; DTP hopping; BPDU Guard; Evil Twin	6	רב-ברירה
Diffie-Hellman, צופן קיסר mod 26, מפתח ציבורי/פרטי, AES מול hash (סודיות)	7	רב-ברירה
TCP/IP על IPsec	8	רב-ברירה
בקורות מנהליות / פיזיות / לוגיות; Nmap	9	התאמה / רב-ברירה

פתרון מלא - חלק ב' של שאלון הדוגמה (735001), תשפ"ג

כדי שתוכלו לפתור עם התלמידים בסוף השנה. ההסברים מופיעים בהרחבה בפרקים.

שאלה (20) 4 נק'

- א. הודעת "UPS - Last Call - Confirm Now" - תשובה 4: Social Engineering (phishing). סימנים: שולח מ-hotmail.com ולא מדומיין UPS, דחיפות ("Last Call"), כפתור לאישור פרטים.
- ב. זיהוי ואימות משתמשים = Authentication; ניהול הרשאות = Authorization; רישום למעקב = Accounting.
- ג. ניטור + חסימה אוטומטית = IPS; ניטור + התראה בלבד = IDS.
- ד. חסימת 20.20.20.0/24 ב-ACL סטנדרטי: תשובה 2: `access-list 10 deny 20.20.20.0 0.0.0.255` (מספר 1-99 = סטנדרטי; wildcard 0.0.0.255).
- ה. RADIUS 1. מצפין רק את הסיסמה - נכון. RADIUS 2. מבצע אימות ולא מתייחס להרשאות - נכון (RA-DIUS משלב authentication+authorization בתהליך אחד ואינו מאפשר הרשאה נפרדת לכל פקודה). TACACS 3. משתמש רק ב-UDP - לא נכון TACACS 4. (TCP 49) + מספק שירות AAA - נכון.
- ו. הסכמה על מפתח פרטי בערוץ ציבורי - Diffie-Hellman: 2.

שאלה (9) 5 נק'

- א. `R1(config)# aaa new-model`
- ב. מפתחות RSA - 2: ניתן להשתמש בהם לצורך חיבור SSH (ללא איפוס).
- ג. modulo 26 - 4: מספר האפשרויות (האותיות) בשפה האנגלית; ה-"mod" ממגלגל חזרה מ-Z ל-A.
- ד. הצפנה במפתח ציבורי $\Rightarrow$ פענוח ב-1: מפתח פרטי.
- ה. סודיות (confidentiality) של מידע מוצפן - AES 3: MD5/HASH = שלמות; WPA-2 הוא פרוטוקול, לא אלגוריתם).

שאלה (12) 6 נק'

- א. IPsec נועד לאבטח את חבילת הפרוטוקולים TCP/IP: 2 (שכבה. 3).
- ב. מנהלי = כתיבת מדיניות, הנחיות, נהלים, תקנים; פיזי = הגנה על חדר שרתים וארונות תקשורת; לוגי = רשימות גישה, סיסמאות, מערכות למניעת גישה.
- ג. Script kiddies = משתמש בכלי פריצה בלי להיות מודע לתהליכים; Hacktivist = תוקף מתוך אמונות ומניעים אידיאולוגיים; Insider = משתמש בגישה מורשית לצרכים זרים.
- ד. Nmap - 3: גילוי, ניתוח ובקרה ברשתות תקשורת (סריקת פורטים ומארחים).
- ה. Evil Twin - 1: נקודת גישה זדונית עם SSID זהה לנקודה חוקית.

שאלה (9) 7 נק'

1. א. ניחוש סיסמה בעזרת מילון – Brute force attack: 4 (התקפת מילון היא תת-סוג).
2. ב. port security – MAC table overflow: 1 על כל הממשקים שאינם trunk + הגבלת מספר כתובות MAC.
3. ג. השבתת DTP מונעת VLAN hopping: 3 (switch spoofing).
4. ד. BPDU Guard גלובלי – 3: **spanning-tree portfast bpduguard default** (תשובה 2 גם נכונה תחבירית לממשק בודד – **spanning-tree bpduguard enable** – אך התשובה המצופה היא 3).
5. ה. חסימת 192.168.2.0 ל-192.168.3.0 בלבד: 2 – **deny 192.168.2.0 permit any**, ומחילים out על G0/2 (הממשק שיוצא לרשת המוגבלת). סדר השורות קריטי: **permit any** קודם היה מבטל את ה-**deny**.

סביבת מעבדה מומלצת

- Cisco Packet Tracer (חינם דרך Cisco Networking Academy) – תומך ב: SSH, AAA עם RA-port security, BPDU guard, DHCP snoop-, IOS IPS (חלקית), DIUS/TACACS+, ACL, ZPF ing, GRE. IPsec site-to-site זה מכסה כמעט את כל המעשי בקורס.
- Wireshark – להדגמת Telnet בטקסט גלוי מול SSH מוצפן (פרק 2), ולהצגת handshake של TLS (פרק 7).
- Nmap / Zenmap – רק ברשת מעבדה מבודדת ובאישור בית הספר (פרק 9). אף פעם לא על רשת בית הספר או האינטרנט.
- אתרי הדגמה: cryptii.com (צופן קיסר/ויז'נר), sha256algorithm.com (הדמיה של גיבוב).

חשוב – אתיקה ומשמעת

בקורס הזה מלמדים איך התקפות עובדות כדי לדעת להגן. הבהירו לתלמידים כבר בשיעור הראשון: הרצת סורקים, כלי פריצה או ניסיונות "לבדוק" את רשת בית הספר ללא אישור בכתב היא עבירה על חוק המחשבים (1995) – ותאמרו להם זאת במפורש. פרק 9 מקדיש לכך חלק.